🌐 Module 04: Social Engineering Penetration Testing Methodology

```
# Exercise 2: Sniff Credentials using Dark-Phish
```

Scenario

Dark-Phish is a specialized phishing tool designed for educational purposes and security testing. It is capable of simulating phishing attacks and facilitating the evaluation of system vulnerabilities and user awareness levels.

Here, we will sniff user credentials using Dark-Phish.

Objective

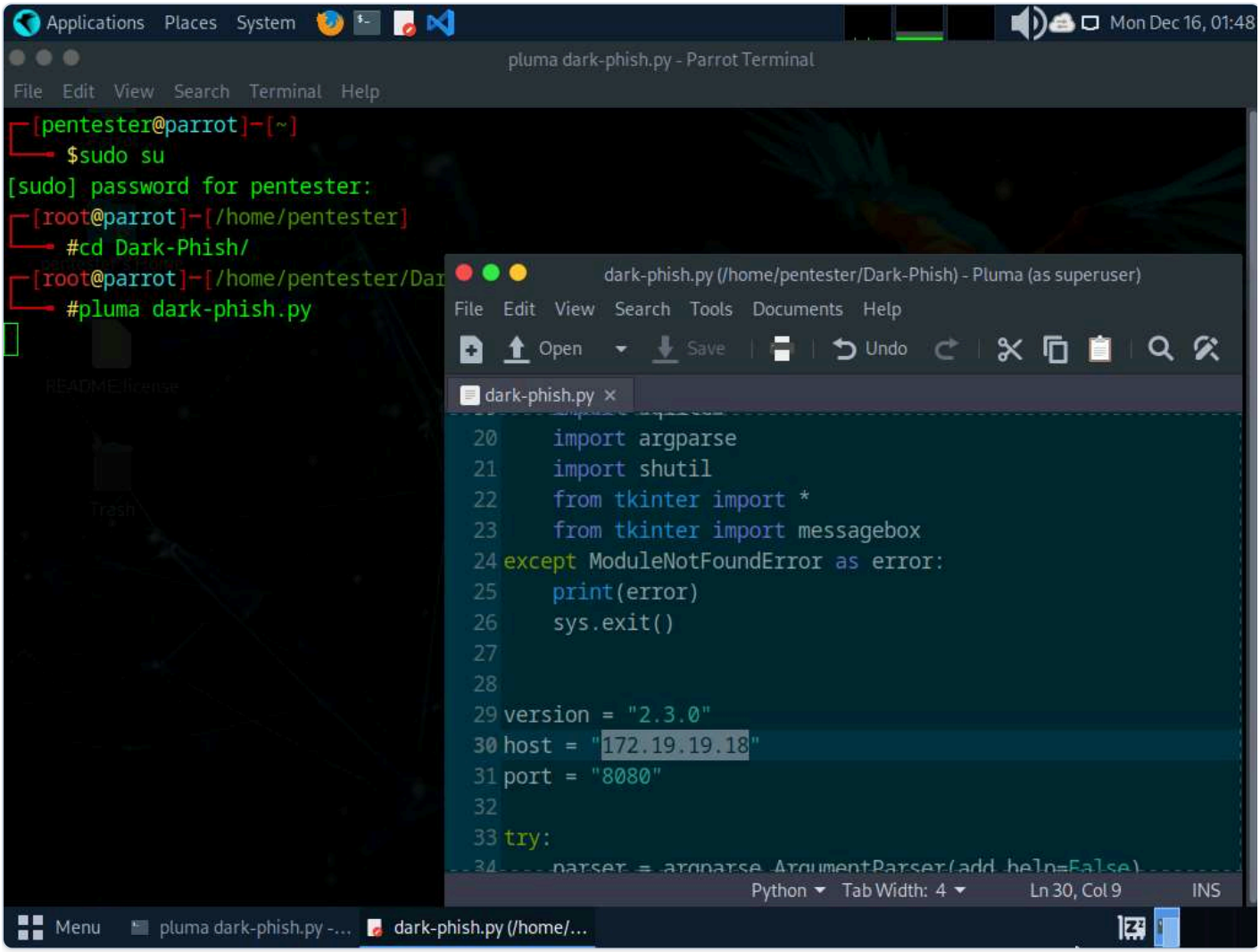
The objective of this lab is to help students learn how to sniff user credentials using Dark-Phish by hosting a local phishing server and harvesting credentials from a remote target machine.

Task 1: Sniffing Credentials using Dark-Phish

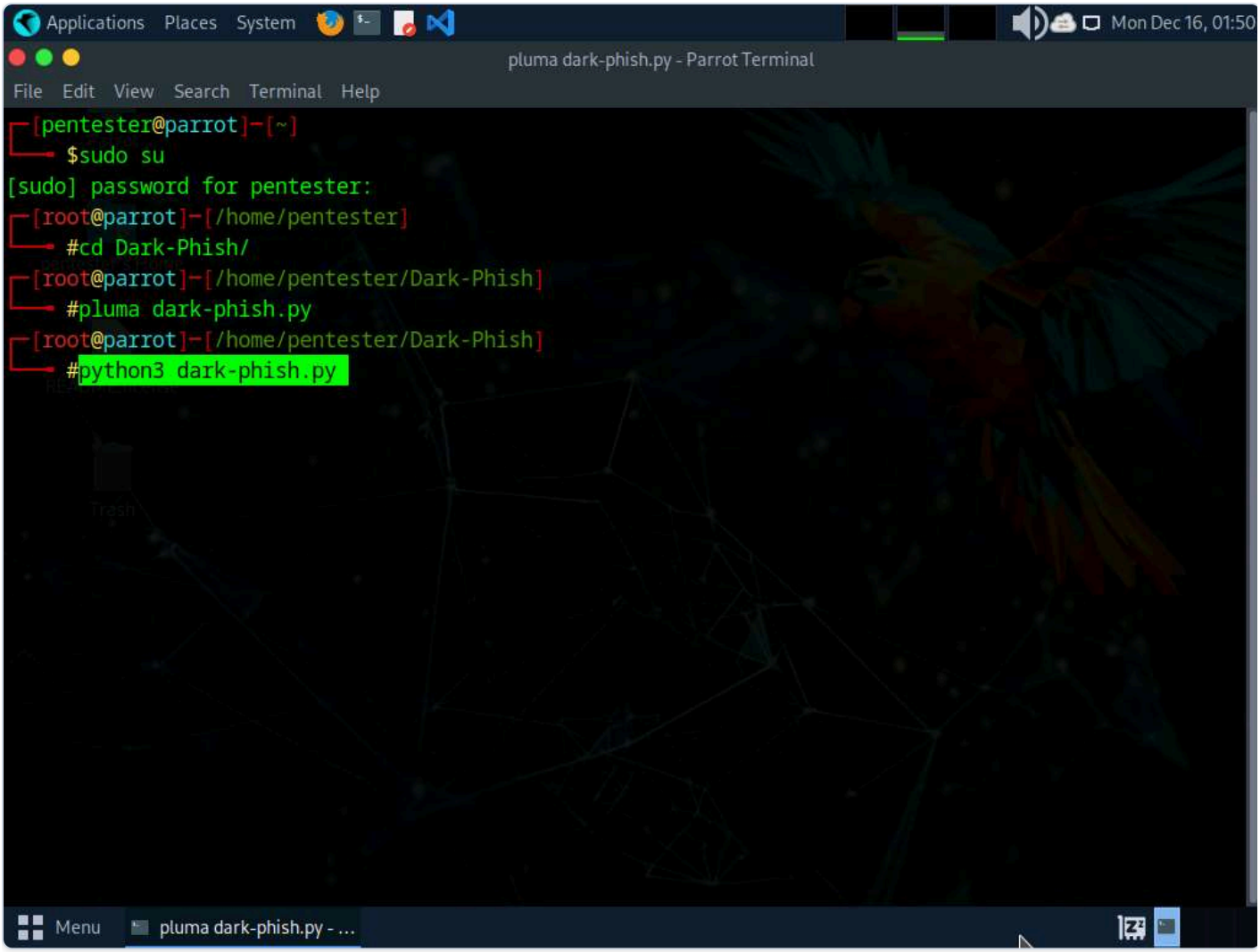
In this task, we will configure and launch Dark-Phish on the Parrot Security machine to capture victim credentials using a simulated Google sign-in page.

Lab Tasks

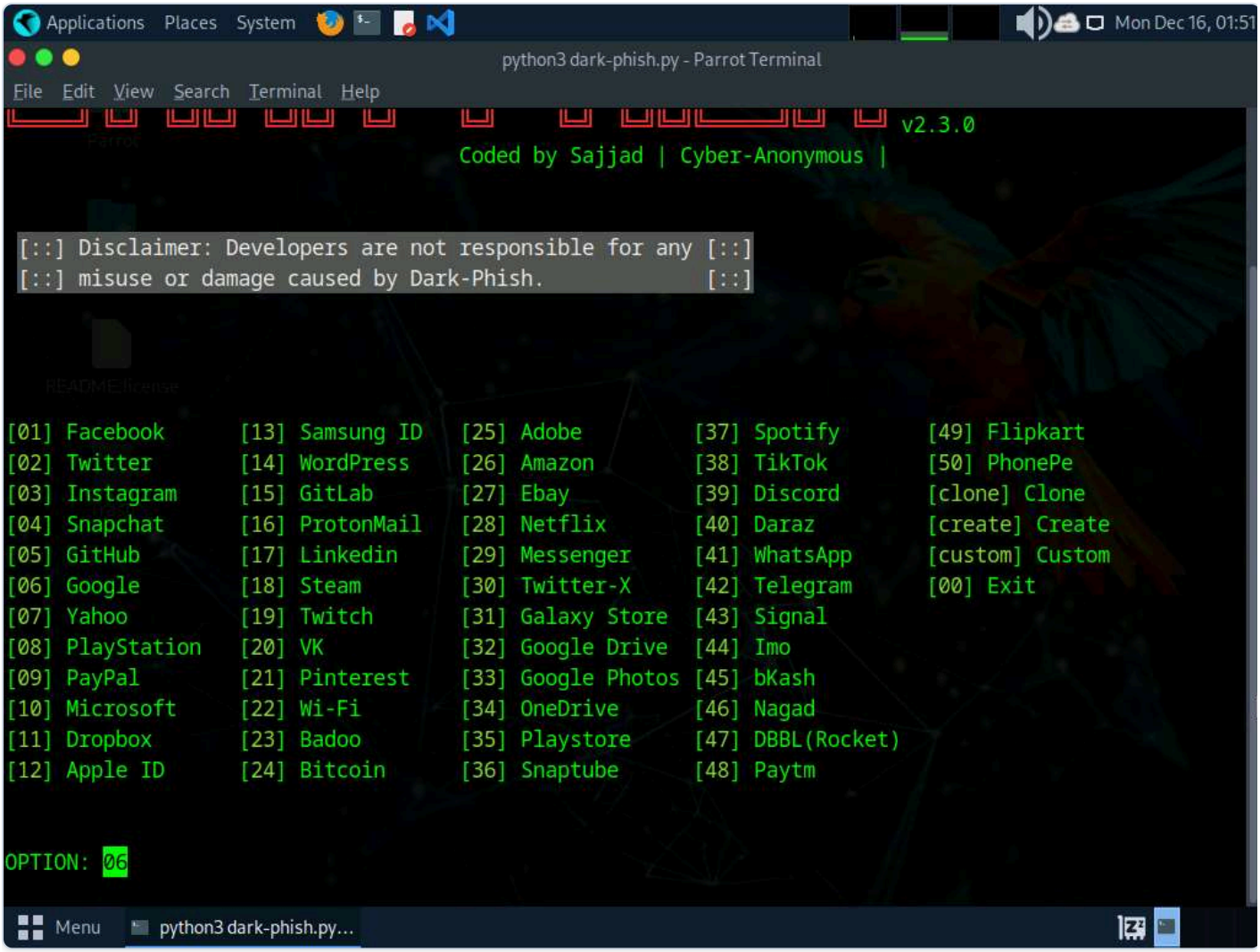
1. On **Parrot Security**, open a Terminal window, and execute **sudo su** to run the programs as a root user (When prompted, enter the password **toor**).
2. Run **cd Dark-Phish/** to navigate to the Dark-Phish directory.
3. In this task, we will be hosting the PHP server on the local host. To do so, we need to change the localhost IP address in the **dark-phish.py** file.
4. In the terminal window, type **pluma dark-phish.py** to edit the Python script in the Pluma text editor.
5. In the text editor, replace `127.0.0.1` with **172.19.19.18** in line 30 under the host field, save the file, and close the text editor window.



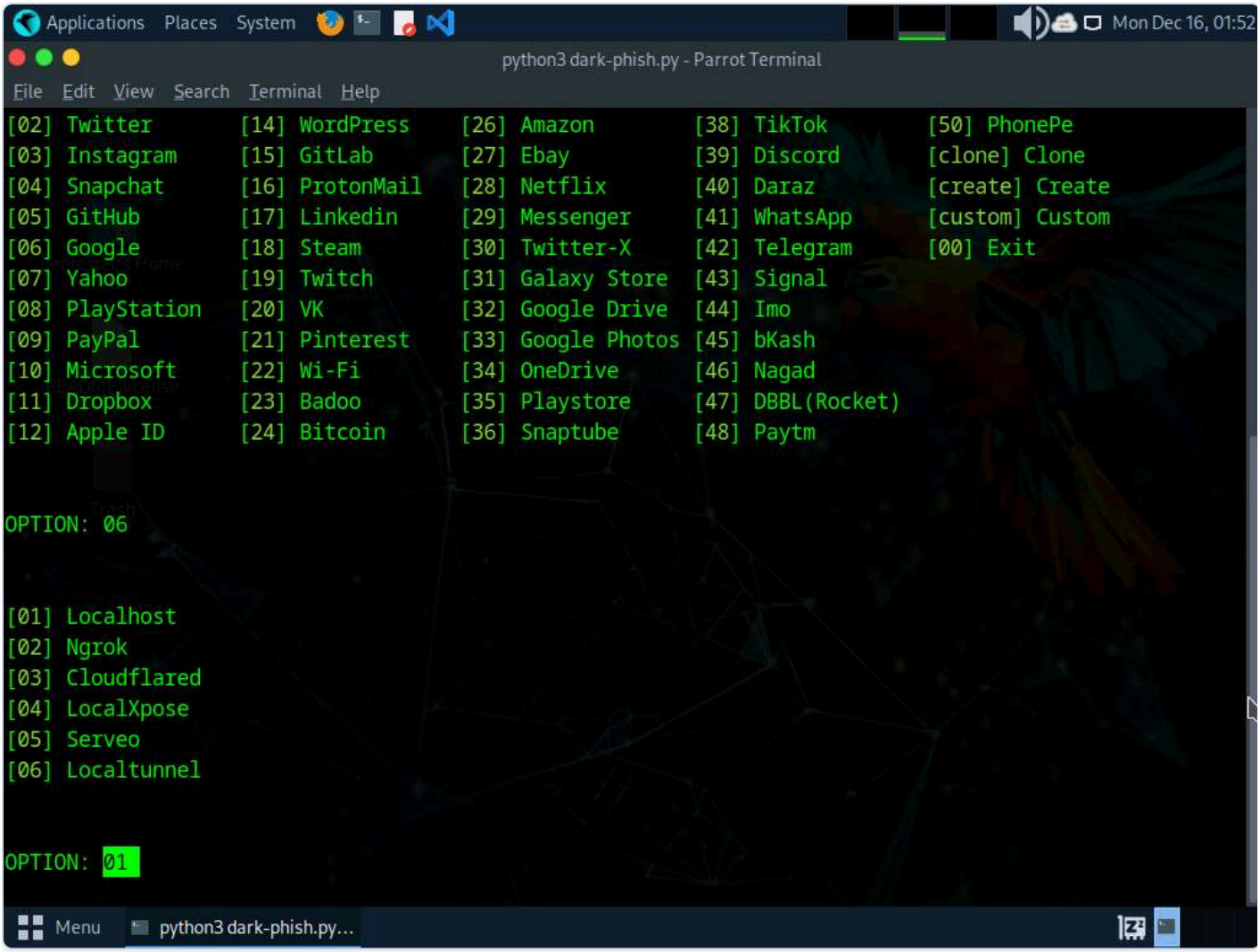
1. Launch Dark-Phish by executing the **python3 dark-phish.py** command.



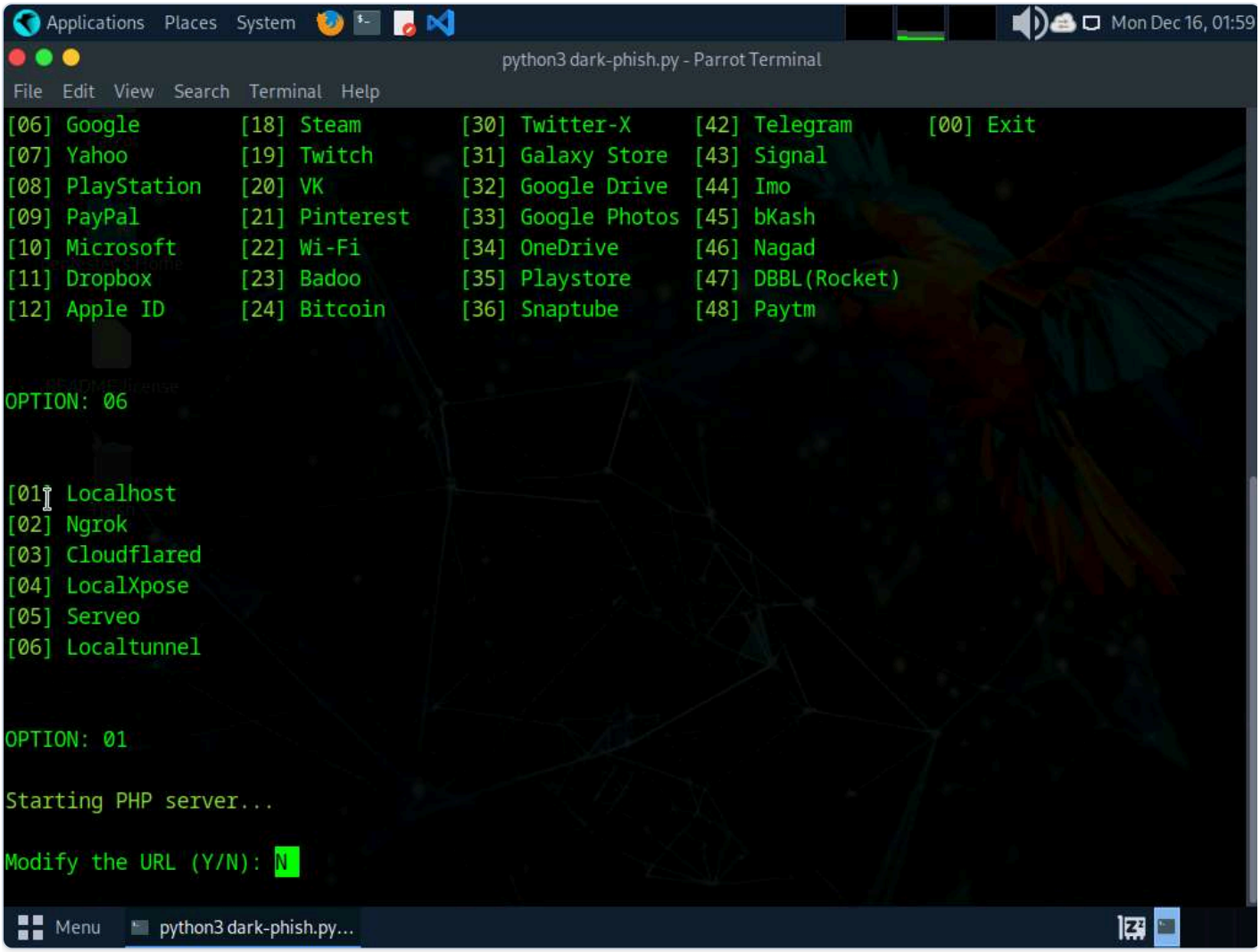
1. The Dark-Phish menu appears as shown in the screenshot. You can observe numerous platform options presented by Dark-Phish. Now, type **06** and press Enter to choose **Google**.



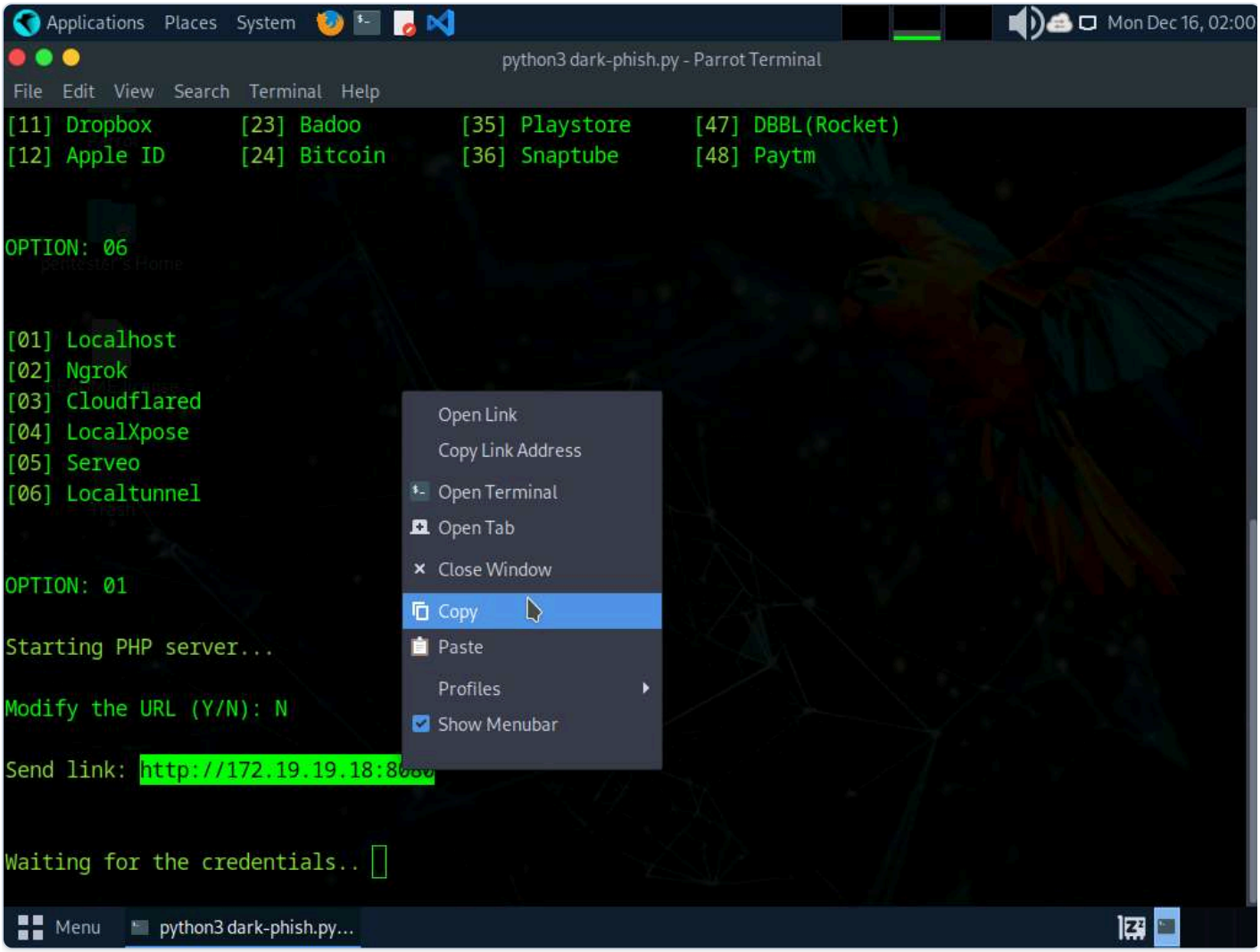
1. A list of hosting options appears; type **01** and hit Enter to choose **Localhost**.



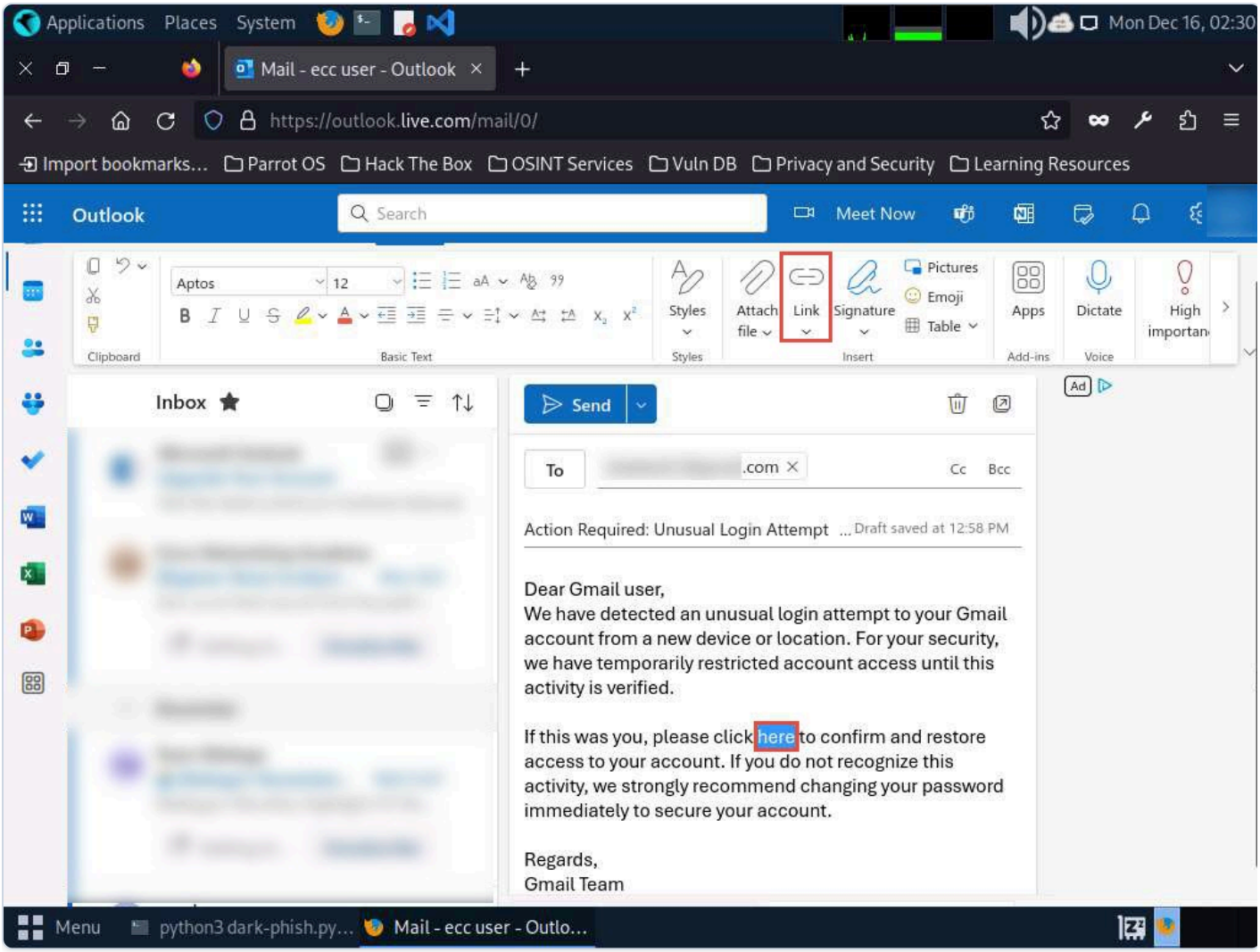
1. Modify the URL (Y/N) option appears; type **N** and press Enter.



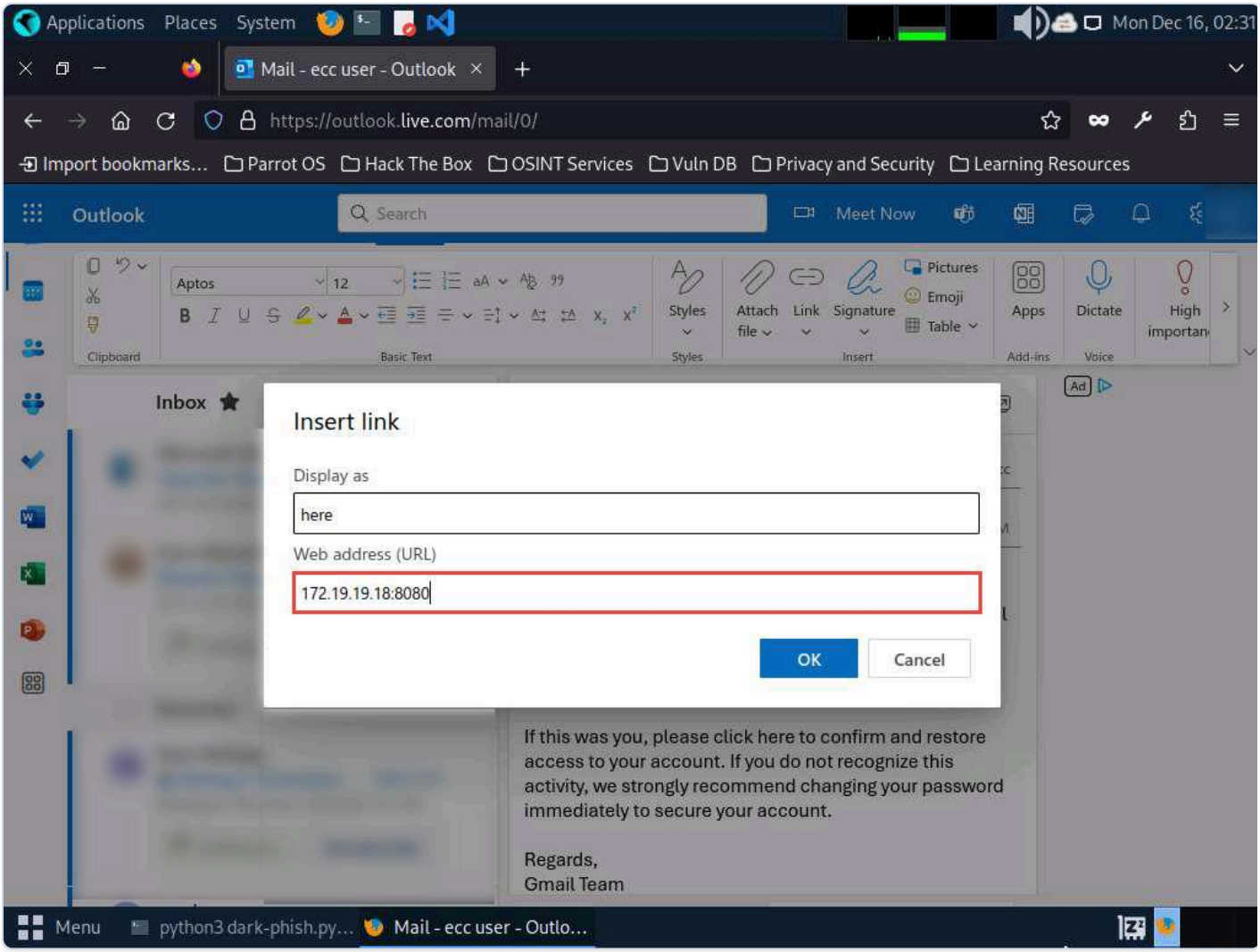
1. Send link appears. Having successfully generated a phishing link, you must now send this link to a victim and try to trick them into clicking it. So, copy the link.



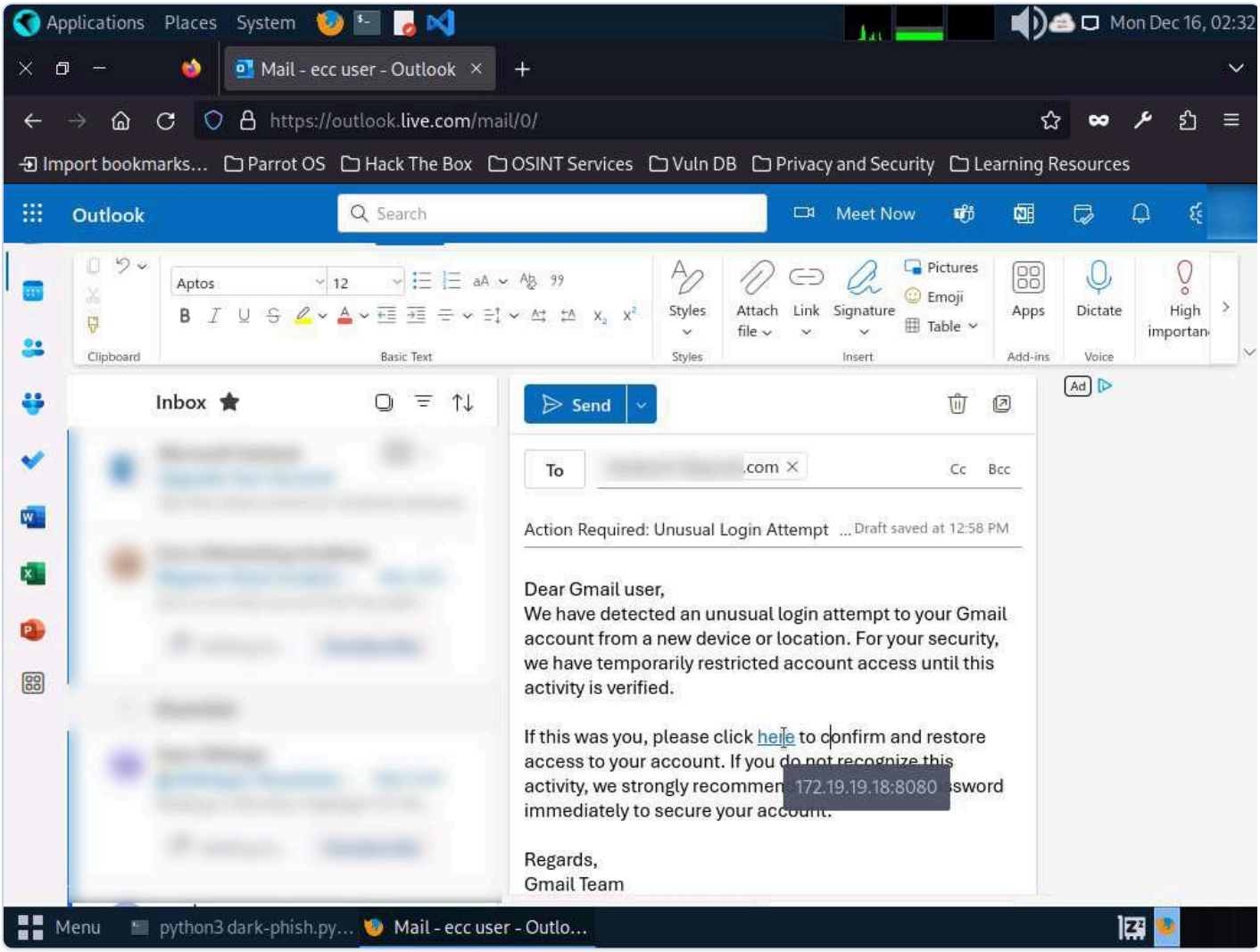
1. Launch a web browser (here, Mozilla Firefox) and open your email account (in this example, we are using Outlook). Log in and compose an email.
   - *(You can log in to any email service of your preference.)*
2. After logging into your email account, click the **New Mail** button in the left pane and compose a fake but enticing email to lure a user into opening the email and clicking on a malicious link.
3. Select "here" to place the fake URL, then switch to Messages from the toolbar and click the **Insert link** icon.



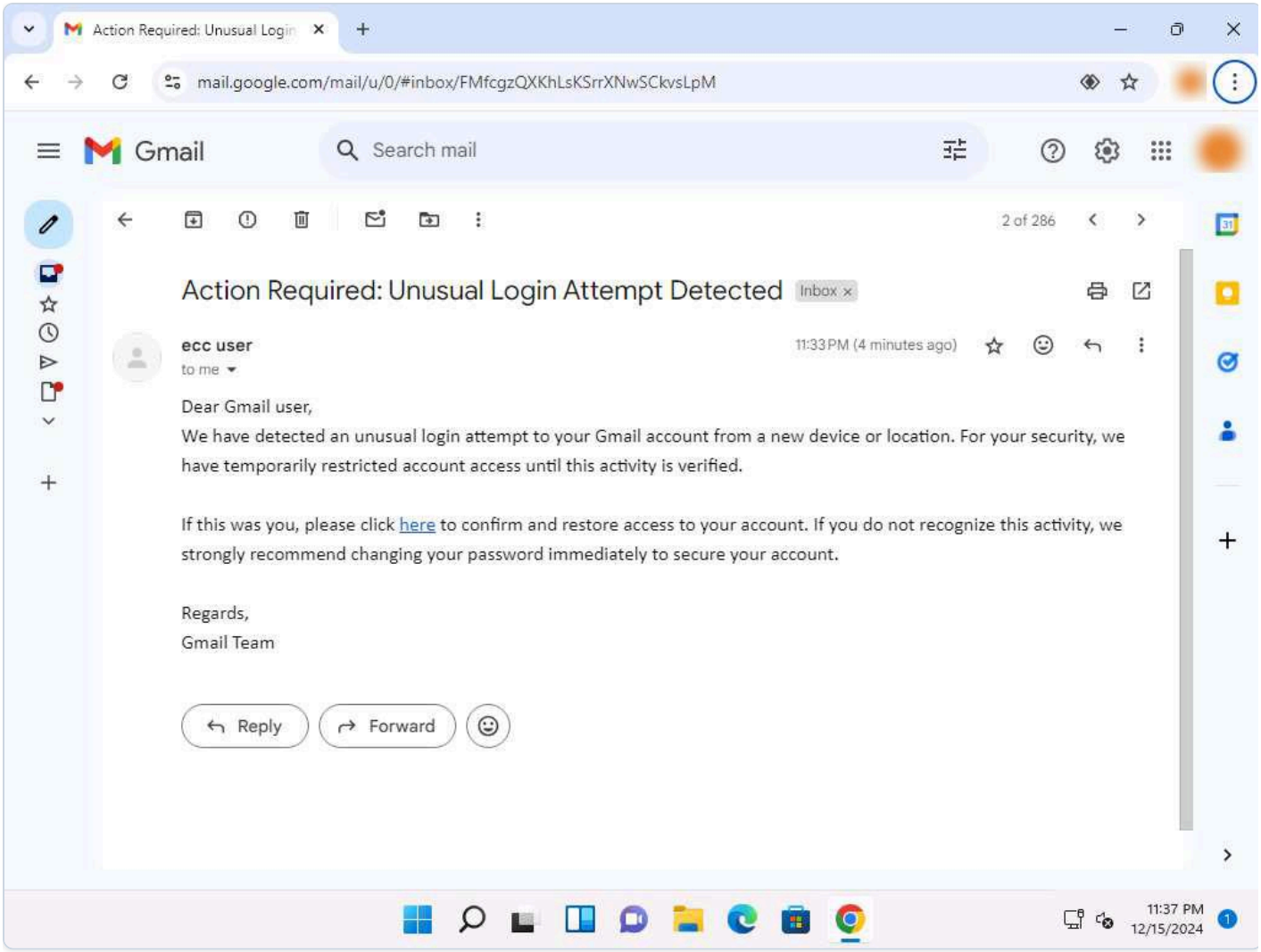
1. Paste the copied Send link in the Insert link window under the Web address (URL) field and click **OK**.



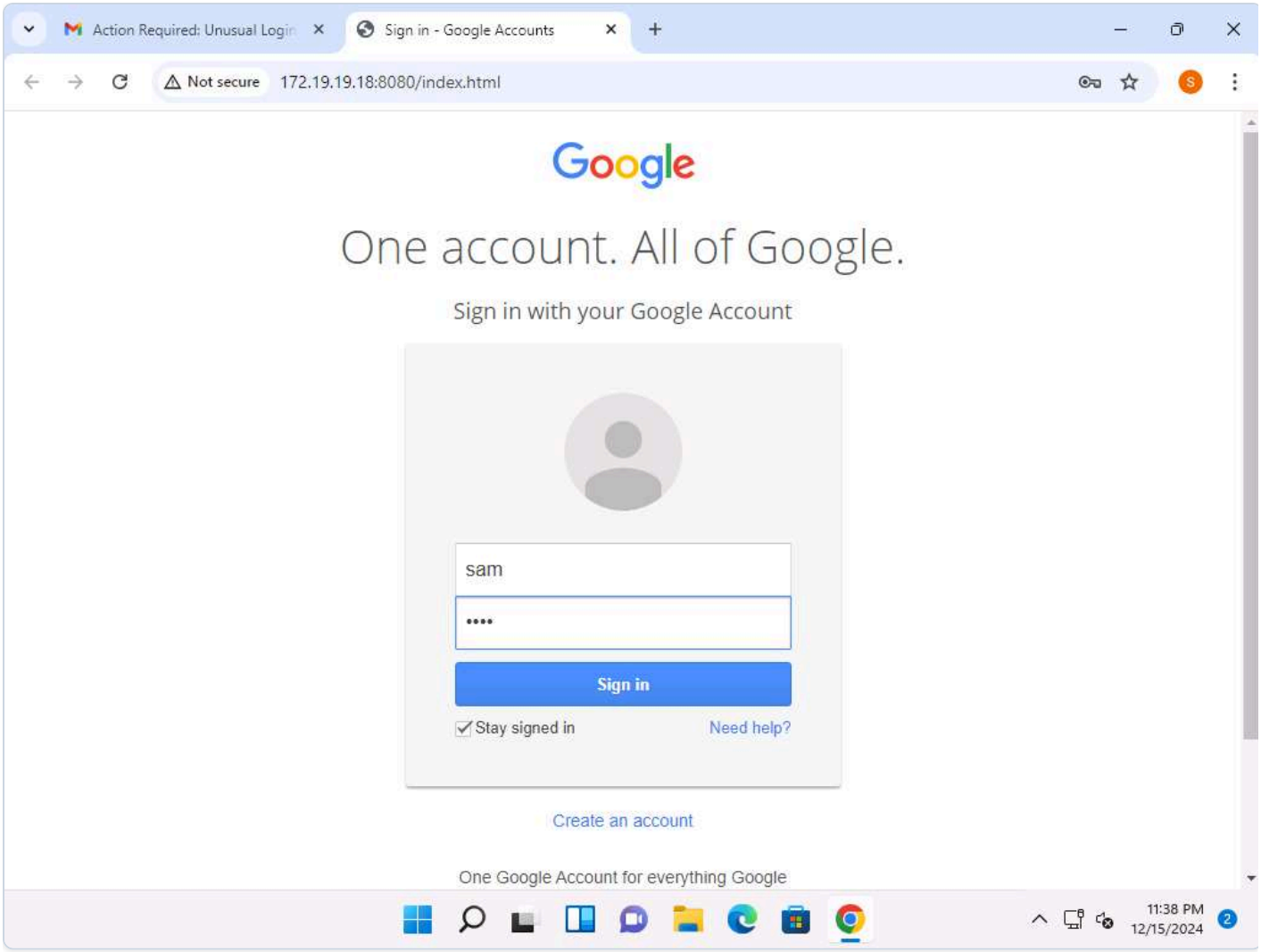
1. To verify the URL, hover over the hyperlink, and the full URL will appear. Once verified, send the email to the intended user.

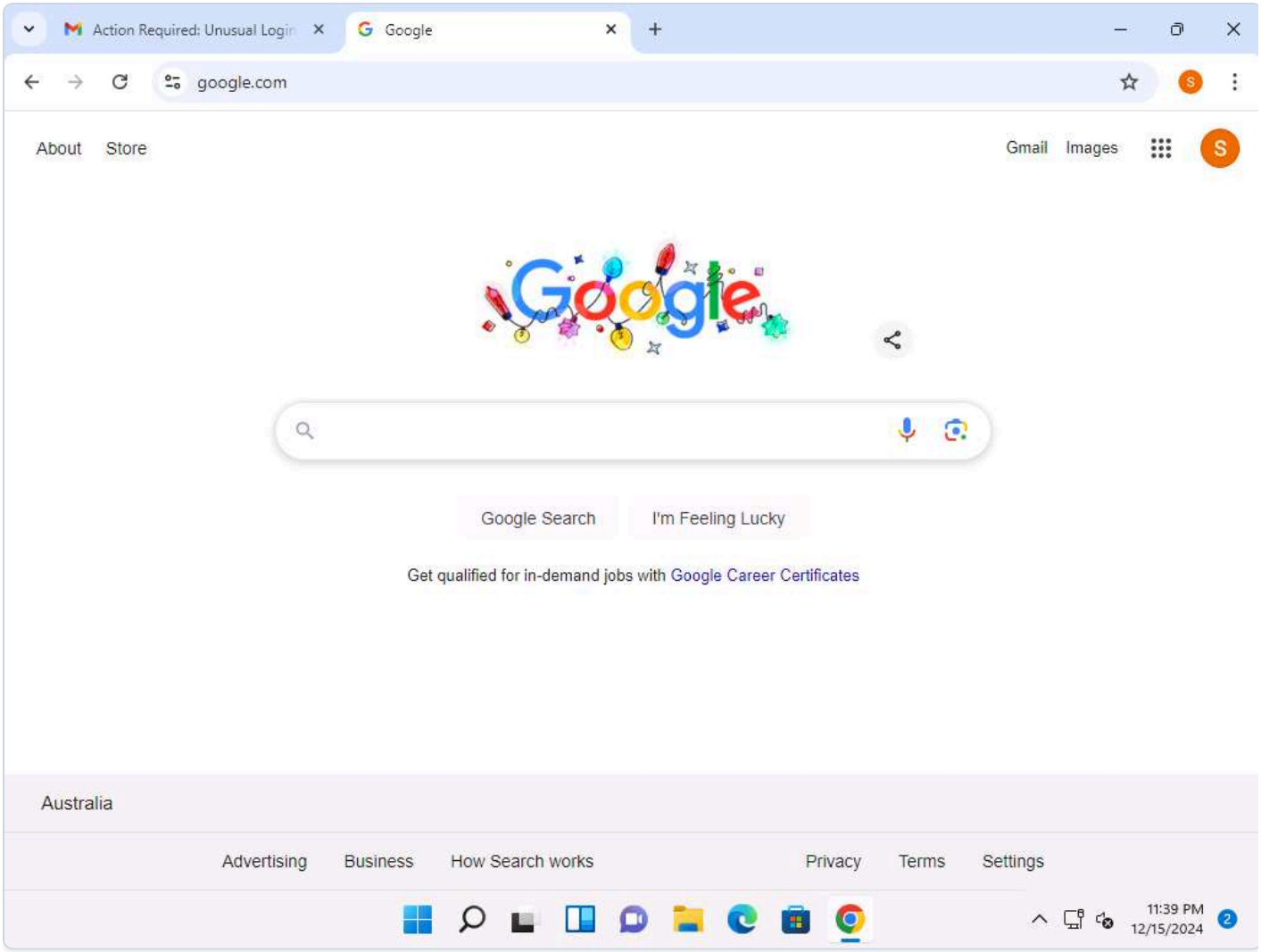


1. Click **Sales Department** to switch to the Sales Department machine. Login with **Admin** / **test@123**.
2. Open the Google Chrome browser and sign in to the email account to which you sent the phishing mail as an attacker. Open the email you sent previously and click to open the malicious link.
   - *(If the email does not appear in your Inbox, check the Spam folder. If a pop-up appears, click Open anyway.)*

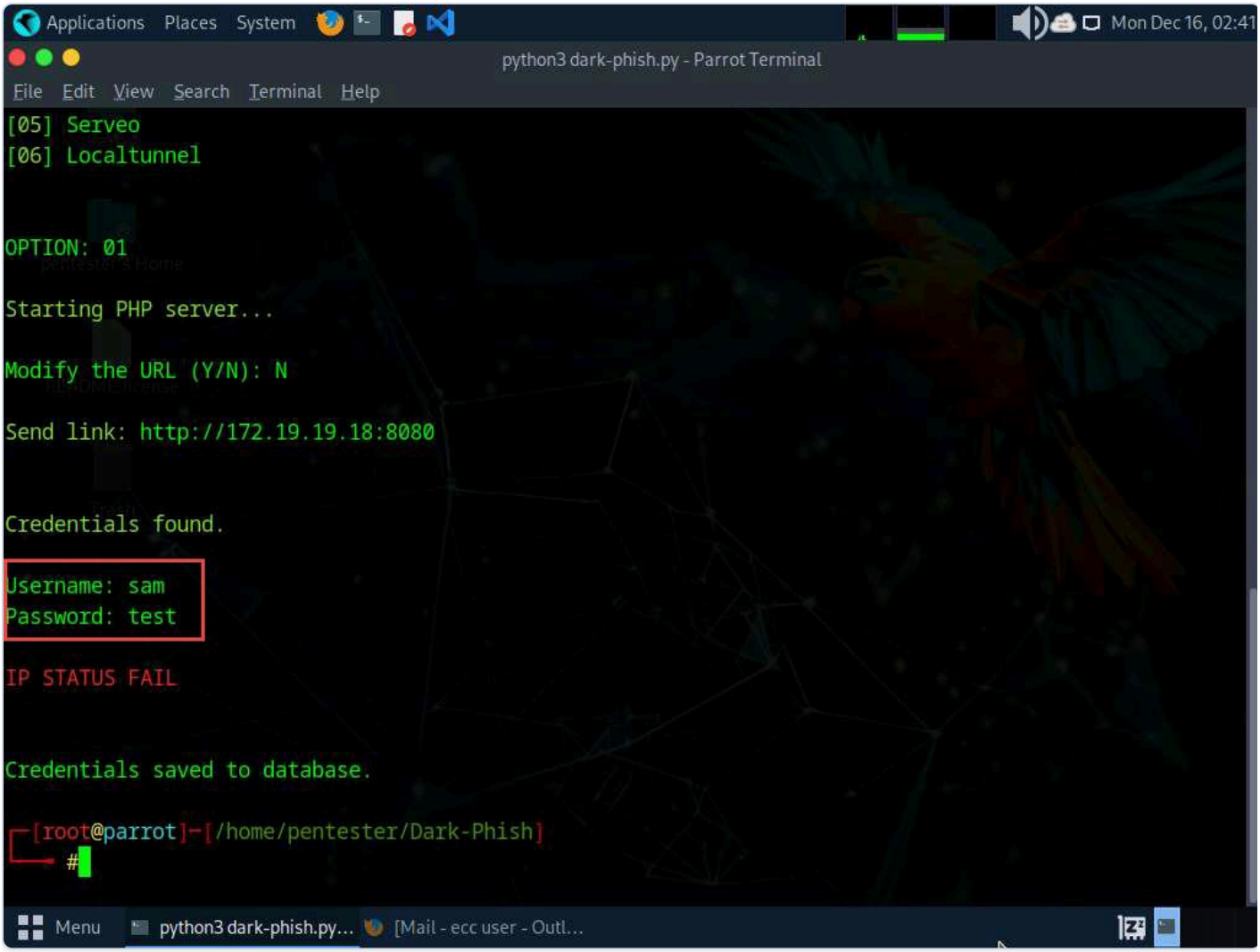


1. When the victim (you in this case) clicks the URL, a new tab opens, and displays a replica of the Google sign-in page.
2. The victim will be prompted to enter the username and password into the form fields, which appear as they do on a legitimate website. When the victim enters the Username and Password and signs into it, they will be redirected to the legitimate Google page. Note the different URLs in the browser address bar for the cloned and legitimate sites.


Action Required: Unusual Logi
Sign in - Google Accounts
Not secure
172.19.19.18:8080/index.html
Google
One account. All of Google.
Sign in with your Google Account
sam
Sign in
Stay signed in
Need help?
Create an account
One Google Account for everything Google
11:38 PM
12/15/2024



1. Now, click **Parrot Security** to switch back to the Parrot Security machine and switch to the terminal window. Soon after the victim clicks Sign in, Dark-Phish records the credentials. The attacker can then use these to gain unauthorized access to the victim's account.
2. The captured credentials are displayed in the terminal.



This concludes the demonstration of phishing user credentials using the Dark Phish. Close all open windows and document all the acquired information.

> **IMPORTANT:** ❓ **Question 4.2.1.1** On the Parrot Security machine, utilize Dark-Phish to capture user credentials from a remote machine. How many hosting options are available in Dark-Phish. [!SUCCESS] ✅
> **Answer:** **06**